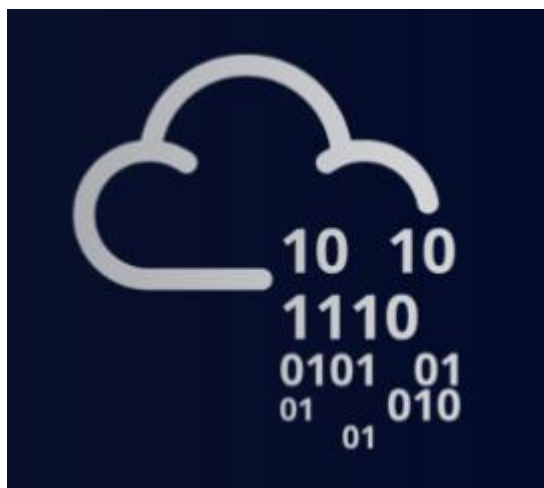


Incident Response lifecycle

TEXTBOOK with PRACTICAL examples



Date: 16/08/2026

Created by: Adam Křelina (feat. Tryhackme)

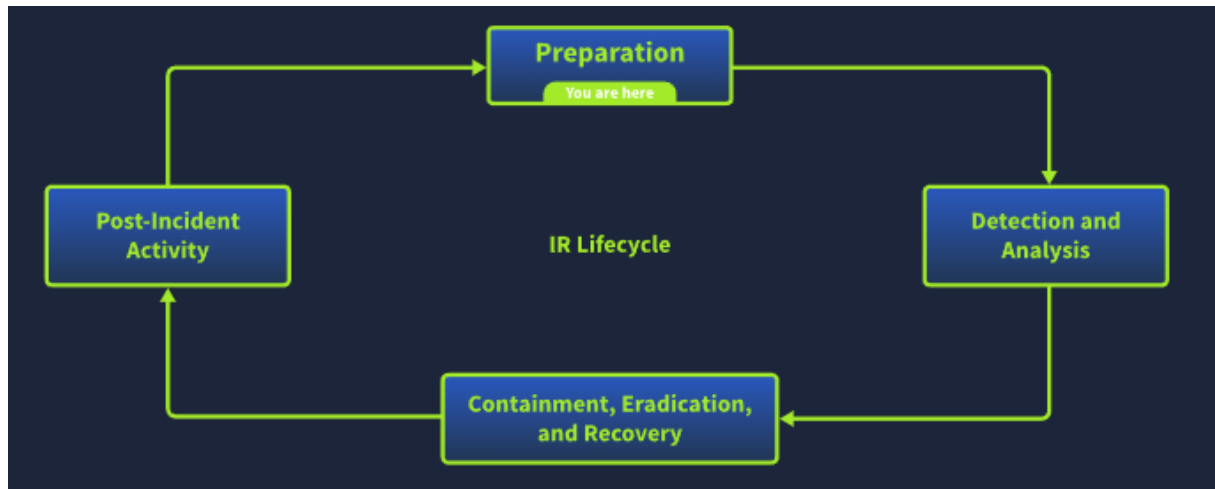
Number of rooms: 4 (full module)

Contents

Incident Response lifecycle	1
PREPARATION	3
What is incident response?	3
Incident Response Frameworks	4
NIST SP 800-61	4
People, processes and technology.....	5
PRACTICAL	9
DETECTION AND ANALYSIS	13
IR Triggers and Communication	14
Team Communication during IR.....	14
ESSENTIAL TOOLS FOR DETECTION AND ANALYSIS PHASE.....	15
PRACTICAL	16
Response and Recovery	21
Stopping the damage in a Microsoft 365 environment	22
MITRE ATT&CK and containment decisions.....	22
Eradication	23
Recovery.....	23
PRACTICAL	25
CONTAINMENT PRACTICAL.....	26
ERADICATION AND RECOVERY PRACTICAL.....	28
POST-INCIDENT ACTIVITY (phase where the intelligence is gathered).....	32
Lessons learned meeting	32
Reporting the incident.....	32
The Executive Summary	33
The Technical Summary	33
Strengthening the Defenses	34
PRACTICAL	35

PREPARATION

The important part of proper preparation is for organization to have the right people, processes and technologies in place.



What is incident response?

Organizations of every size face adversarial threats daily, and the question is never whether an incident will occur, but whether the organization is ready to respond when it does.

Incident response is the structured approach an organization takes to prepare for, detect, contain and recover from security incidents while minimizing damage and reducing recovery time.

Three important words:

Event	Any observable occurrence within a system or network. They happen constantly; vast majority are completely normal. A user logging in, an email being delivered, and a file being opened are all events. Notable events are transitioned into alert thanks to detection rules and security tools.
Alert	A notification generated by a security tool indicating that something may require attention. Not every alert represents a real threat. Alerts can be escalated to incidents after a thorough alert triage.
Incident	A confirmed violation of security policies or practices that has a negative impact on the organization. An incident is declared when evidence confirms that a threat is real and action is required. (True positive)

An Incident response process can be triggered by many sources (not just alert from SIEM), for example:

- A security alert escalated by a SOC analyst
- A user reporting suspicious email or unexpected account behavior
- An automated detection from an EDR or SIEM tool
- A third party (Threat Intelligence provider or law enforcement) notifying the organization
- A threat intelligence feed flagging infrastructure associated with the organization

Nexus Financial handles this by having a security team in place to effectively register incidents. SOC engineers ingest events and build detection rules, SOC analysts triage alerts and analyze threat, and a compliance team handles incident reports from partners and external parties. = this ensures proper and formal handling of an incident.

Incident Response Frameworks

In a situation when incident occurs everything can get messy and people respond under pressure, decisions need to be made quickly, evidence preserved, and multiple teams need to coordinate simultaneously. A framework provides the IR team with a proved, repeatable process to follow regardless of the type of severity.

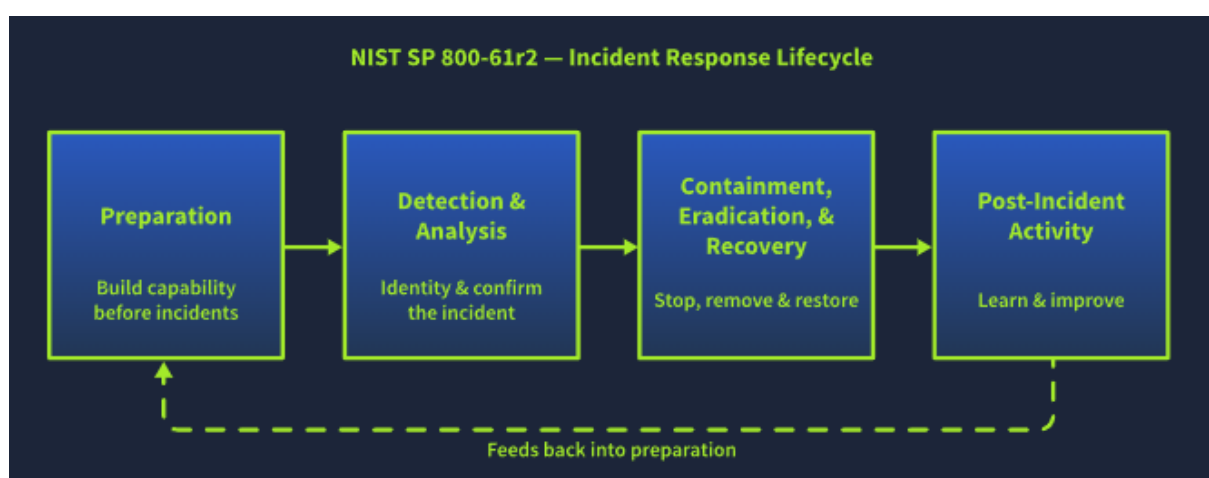
NIST SP 800-61

The National Institute of Standards and Technology published the Computer Security Incident Handling Guide (SP 800-61 – revision 2). It is some of the most widely referenced incident response frameworks in the industry and defines a four-phase IR lifecycle.

Phase	Description
Preparation	Covers all the work done before an incident occurs. (Building the IR team, defining policies and procedures, deploying detection tools, and ensuring adequate logging and visibility across the environment)
Detection and Analysis	Covers the identification of potential incidents, the triage of alerts, and the analysis required to confirm that an incident has occurred and understand its nature and scope.
Containment, Eradication and a Recovery	Covers the active response to a confirmed incident. Containment limits further damage, eradication removes the

	threat from the environment, and recovery restores normal business operations.
Post-Incident Activity	Covers the lessons learned process. This includes reviewing what happened, documenting the findings, and using what was learned to improve the organization's defenses and response procedures.

The importance of this framework is that it's a cycle!, which means it eventually after the post-incident activity goes back with the updates to the Preparation part, making the organization better equipped for the next incident.



Nexus Financial has an incident response policy in place that references NIST SP 800-61 as its guiding framework. The policy defines the IR phases, assigns roles to CSIRT members, and outlines communication procedures (same language so everyone understands what's happening).

People, processes and technology

Effective incident response is built on three pillars:

- the right people with the right skills
- well-defined processes that guide their work
- technology that supports detection and investigation

People = CSIRT (Cyber Security Incident Response Team) = CERT

CSIRT members require appropriate access to the systems and data needed to do their work. This access should follow the principle of least privilege, granting only what is

necessary for each member's role, audited regularly, and formally approved rather than assigned permanently.

IR responders must be proficient with forensic tools, log analysis, and investigative techniques. End users must know how to recognize suspicious activity and report it through the correct channels. Regular phishing simulation and awareness campaigns build this capability over time.

Processes

Define how the IR team operates.

Incident Response plan	Defines the overall approach the organization takes when managing incidents. Covers roles and responsibilities, escalation paths, communication channels, and how the effectiveness of the response is measured.
Communication Plan	Defines who within the CSIRT is the point of contact for different incident types.
Playbooks	Provides step-by-step procedures for specific incident types such as phishing, ransomware, or data breach. Clear path for responders without being under too much pressure.
Chain of Custody documents	Track the handling of evidence from collection through analysis to storage. Who handled evidence, when and why.
Ticketing Systems	Provide a central record of all investigation activity. Every action taken, every finding made, and every decision reached should be logged.
Asset Inventory	A complete and up-to-date list of all hardware and software within the organization. We cannot identify what has been compromised without knowing what assets exist.

Technology

Technology enables the IR team to detect threats, investigate incidents and respond effectively. No single tool covers everything, and most organizations use a combination of solutions depending on their environment and maturity.

SIEM (Security Information and Event Management)	The central hub of most IR operations. Collects logs from across the environment, correlates events, and generates alerts when suspicious activity is detected.
EDR (Endpoint Detection and Response)	Monitors activity on individual devices and can detect, alert on, and in some cases automatically respond to malicious behavior at the endpoint level.
IDPS (Intrusion Detection and Prevention Systems)	Monitors network traffic for known attack patterns and anomalous behaviour. Detection systems alert on suspicious traffic, while prevention systems can actively block it.
DLP (Data Loss Prevention)	Monitors and controls the movement of sensitive data within and outside the organization. Can detect and block unauthorized data transfers before exfiltration occurs.
Threat Intelligence Platforms	Aggregate and contextualize information about known threats, attacker infrastructure, and malicious indicators. Helps IR Teams understand who they are dealing with and anticipate attacker behaviour.
Forensic Tools	Support the collection and analysis of evidence during an investigation. Includes disk and memory imaging software, packet-capture tools and log-analysis utilities.

Visibility, Logging and Detection

An organization cannot respond to what it cannot see.

Visibility is the ability to observe what is happening across the environment through log collection and monitoring.

Detection is the ability to recognize when something observed is malicious.

Without visibility the IR team is working without evidence.

Every device, system and application within an organization generates log data.

Collecting these logs into a centralized platform such as a SIEM, provides the IR team with a single source of truth for investigations. Logs must be enabled, collected and protected from modification once recorded (integrity must be maintained).

Thanks to logs IR team can reconstruct the attack timeline, identify affected systems and confirm the root cause of a breach.

Types of log entries: (an individual record describing something that happened)

Event log: Records observable occurrences within a system (login attempts, application activity, network connections)

Audit log: Records a sequential history of action taken within a system. Captures who performed an action, what the action was, and how the system responded. (Split into success and failure categories)

Error log: Records system failures such as crashed service or an application error

Types of log sources: (the device, system, or application producing the logs)

Network logs: Come from routers, switches, and firewalls and record traffic flows and connection attempts

Host perimeter logs: Come from proxies, VPN servers

System logs: Come from operating systems on servers and workstations and include login events, process execution and configuration changes

Application logs: Come from business applications, cloud platforms and databases.

Detection gaps

Exists when logs are collected, but no alerting rules or monitoring are in place to flag suspicious activity. Detection rules are must!

PRACTICAL

Nexus Financial uses **Microsoft 365** for email, file storage, and collaboration, and **Entra ID** as its identity and access management platform. All employee accounts are managed through Entra ID, and all email, SharePoint, and Teams activity runs through Microsoft 365.

Start the lab by clicking the **Start Lab Machine** button below. The machine will load in Split View within a few minutes. If it does not appear, click the blue **Show Split View** button at the top right of the page.

Your virtual environment has been set up ✓

All machine details can be found at the top of the page.



Lab machine ⓘ

Status: ● On

Once the VM has loaded, open the **Nexus** folder on the Desktop. This folder contains a selection of Nexus Financial's preparation documents. In reality, an organization would have significantly more documentation, tooling, and processes in place. What is provided here is the material directly relevant to the incident you will be investigating throughout this module. You are only required to review these documents and answer the questions based on their contents.

The documents in the folder are:

- Asset_Inventory
- IR_Policy
- Communication_Plan
- Pentest_Report_2025
- Historic_Incidents

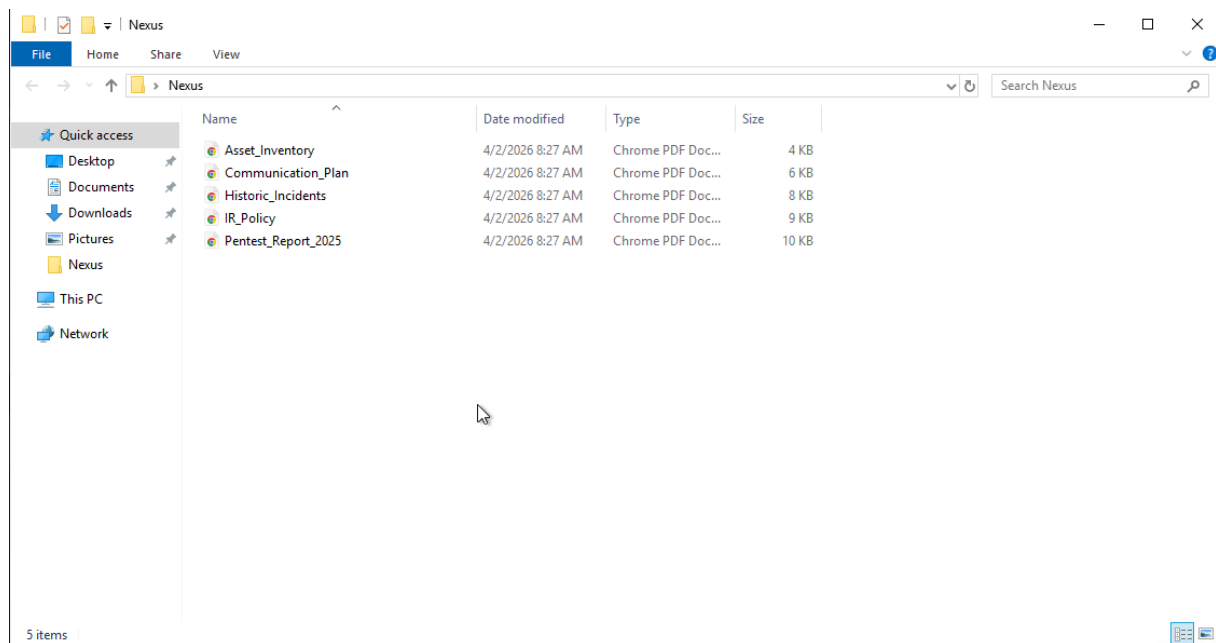
Once you have reviewed the documents, check the local security policies on this workstation (Part of Nexus Financial's Asset Inventory). On the lab machine, open the run dialogue, type **secpol.msc**, and press Enter. This opens the Local Security Policy. Navigate to the **Policies** under **Security Settings**, then review them.

Use the documents and the local security settings to answer the questions below.

According to the task there are two platforms that we have data from:

Microsoft 365 – which manages all email, file storage, collaboration, SharePoint and Teams activities

Entra ID – which manages identity and access management (employee accounts)



1) According to the asset inventory, what is the IP address of the mail server?

HARDWARE ASSETS

ID	Type	Name	IP Address	OS	Owner
NXF-001	Domain Controller	DC-01	10.10.10.1	Windows Server 2022	David Soto
NXF-002	Mail Server	MAIL-01	10.10.10.2	Windows Server 2022	David Soto
NXF-003	SharePoint Server	SP-01	10.10.10.3	Windows Server 2022	David Soto
NXF-004	File Server	FS-01	10.10.10.4	Windows Server 2019	David Soto
NXF-005	Workstation	WS-01	10.10.10.10	Windows 11 Pro	James Willard
NXF-006	Workstation	WS-02	10.10.10.11	Windows 11 Pro	Sarah Kimani
NXF-007	Workstation	WS-03	10.10.10.12	Windows 11 Pro	David Soto
NXF-008	Workstation	WS-04	10.10.10.13	Windows 11 Pro	Marcus Webb
NXF-009	Laptop	LT-01	10.10.10.20	Windows 11 Pro	James Willard
NXF-010	Laptop	LT-02	10.10.10.21	Windows 11 Pro	Sarah Kimani
NXF-011	Network Switch	SW-01	10.10.10.100	Cisco IOS 15.2	David Soto
NXF-012	Firewall	FW-01	10.10.10.254	Fortinet FortiOS 7.4	David Soto
NXF-013	VPN Gateway	VPN-01	10.10.10.253	Fortinet FortiOS 7.4	David Soto
NXF-014	Printer	PRN-01	10.10.10.50	Embedded Firmware	David Soto

2) According to the pentest report, what authentication control is flagged as missing on standard user accounts?

2. FINDINGS SUMMARY TABLE

Ref Title Severity Status

NXF-PT-001 MFA Not Enforced on Standard User Accounts High Open
NXF-PT-002 Email Authentication Controls Not Configured High Open

(SPF, DKIM, DMARC)

NXF-PT-003 No External Email Origin Warning Banner Medium Open
NXF-PT-004 SharePoint Permissions Not Reviewed Medium Open
NXF-PT-005 SIEM Detection Rules Do Not Cover Key M365 Threat Scenarios Medium Open
NXF-PT-006 Security Awareness Training Not Completed Low Open
by All Staff

3. DETAILED FINDINGS

NXF-PT-001: Multi-Factor Authentication Not Enforced on Standard User Accounts

Severity : High

Affected Service: Entra ID -- All standard user accounts

Status : Open -- Not remediated as of March 2026

Multi-Factor Authentication (MFA) is not enforced for standard user accounts

3) According to the pentest report, how many high-severity findings were identified?

2

- 4) According to the historic incidents log, what type of attack was recorded in NXF-INC-001?

ID : NXF-INC-001

Date Reported : 14 July 2025

Date Closed : 16 July 2025

Reported By : Sarah Kimani, HR Director

Severity : Medium

Status : Closed

Type : Phishing Campaign

DESCRIPTION

On 14 July 2025, Sarah Kimani reported receiving a suspicious email purportedly from Microsoft informing her that her account required immediate verification. The email contained a link to a webpage visually similar to the Microsoft 365 login page. Sarah did not click the link and reported it to the SOC team.

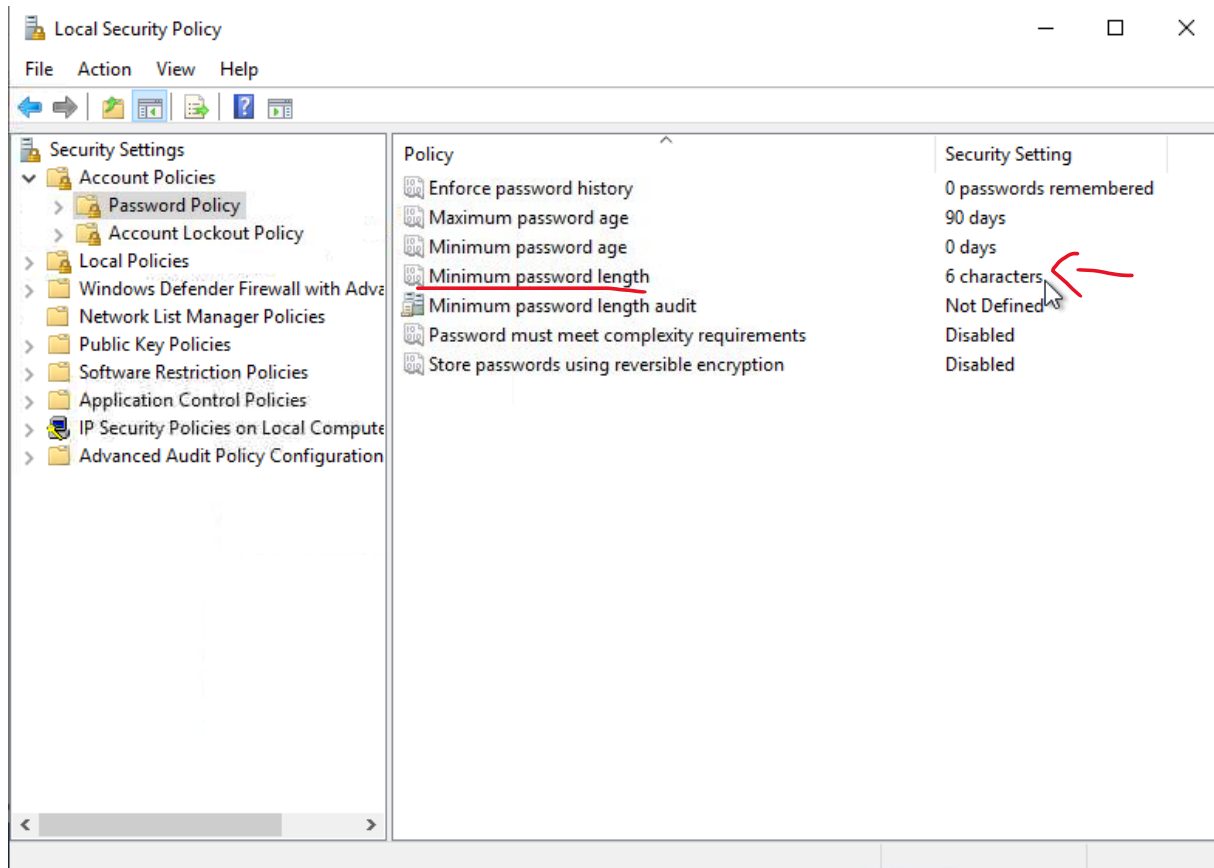
Investigation revealed that the same email had been delivered to three other Nexus Financial employees. None of the recipients clicked the link. The sending domain was identified as a lookalike domain with no affiliation to Microsoft.

ACTIONS TAKEN

- Sending domain blocked at the email gateway
- Affected emails quarantined and removed from all inboxes
- Staff notified via all-staff email to be vigilant of similar phishing
- Incident logged and closed

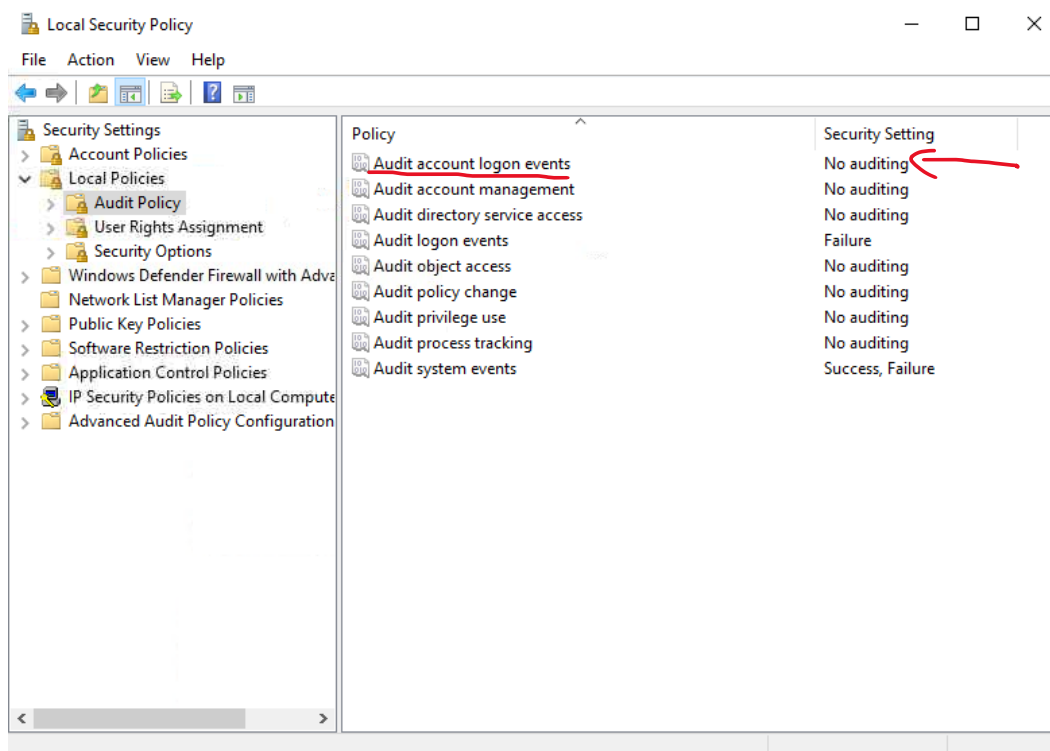
- 5) What is the minimum password length configured on this workstation?

For this task we had to open Local Security Policy (secpol.msc).



6 characters is the correct answer.

6) What is the audit setting configured for Audit account logon events?



DETECTION AND ANALYSIS

Detection and Analysis is the phase where the team responsible for incident response determines whether a security incident has occurred and builds a complete understanding of it. In large organizations, this work is handled by a dedicated IR team that is separate from the SOC.

This phase answers these 2 questions:

- Did a security incident occur, and how did the attacker get in?
- What is the full extent of the damage?

Detection is the process of confirming that a security incident has occurred. It begins the moment a potential threat is noticed, whether through a SIEM alert, a user report, or an automated detection. Not every alert represents a real incident. (true positive x false positive)

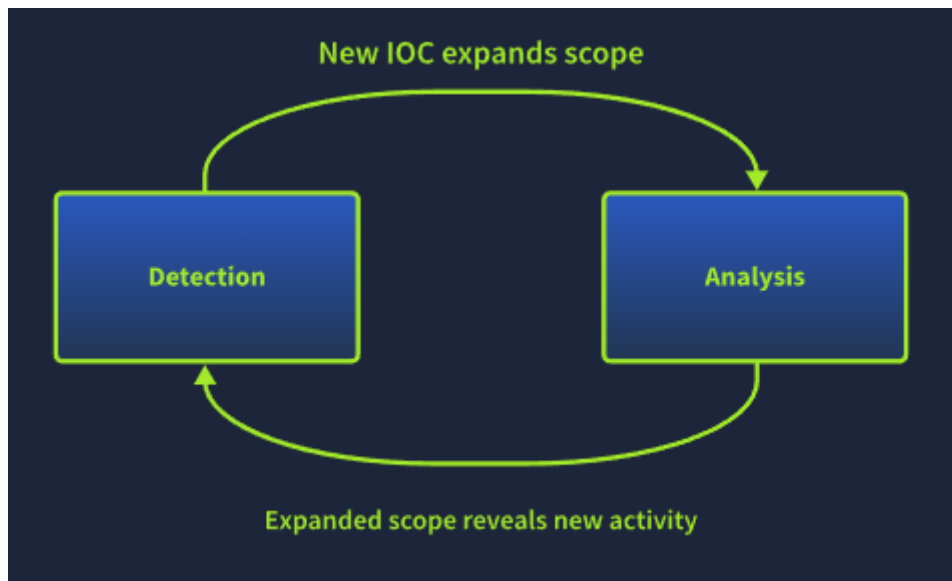
In most SOC environments, detection happens across two levels:

X	SOC L1 Analyst	SOC L2 Analyst
Role in Detection	Initial alert triage	Deep investigation and validation
What they do	Receives alert, does initial validations like checking Ips against threat intel contacting users > determines true/false positive	Validates L1 finding, traces the attack chain, identifies the root cause, and the entry point
Output	Escalation ticket with initial findings	Full incident picture with confirmed IOCs

Analysis begins once an incident is confirmed. Analysis is the process of understanding the full picture of what happened (correlation). It means answering deeper questions about the attack:

- How did the attacker gain initial access?
- Which accounts and systems were affected?
- What data may have been accessed or exfiltrated?
- What actions did the attacker take after gaining access?

Scoping – identifying every affected account, every system accessed and every piece of data that may have been compromised.



IR Triggers and Communication

An incident response process does not start on its own. Something must trigger it. Understanding the different sources that can initiate an IR process is important because relying on a single trigger source, such as automated SIEM alerts, created blind spots.

Common IR triggers:

- SOC alert escalation
- User report
- Automated detection
- Third-party notification (threat intel provider / law enforcement)
- Threat intelligence feed

Detection window differs. (SIEM alerts takes a few minutes, user report a few hours)

Team Communication during IR

Effective communication is as important as technical skill during an active incident.

Common communication failures that slow down IR investigations include:

- delayed escalation because no clear escalation path is defined
- key people not being notified because contact lists are outdated
- MSSP or third-party providers taking days to respond to access requests
- IT Teams unable to provide log access for hours due to approval processes

These delays have real consequences. Every hour an attacker remains uncontained is an hour they can use to deepen their access, exfiltrate more data, or establish additional persistence. A well-defined communication plan with clear escalation timelines directly reduces the time between detection and containment.

Ticketing systems play an important role in keeping communication organized. Every action taken, every finding made and every decision reached during the investigation should be logged in a ticket > this creates an auditable trail that supports post-incident review and lessons learned documentation.

ESSENTIAL TOOLS FOR DETECTION AND ANALYSIS PHASE

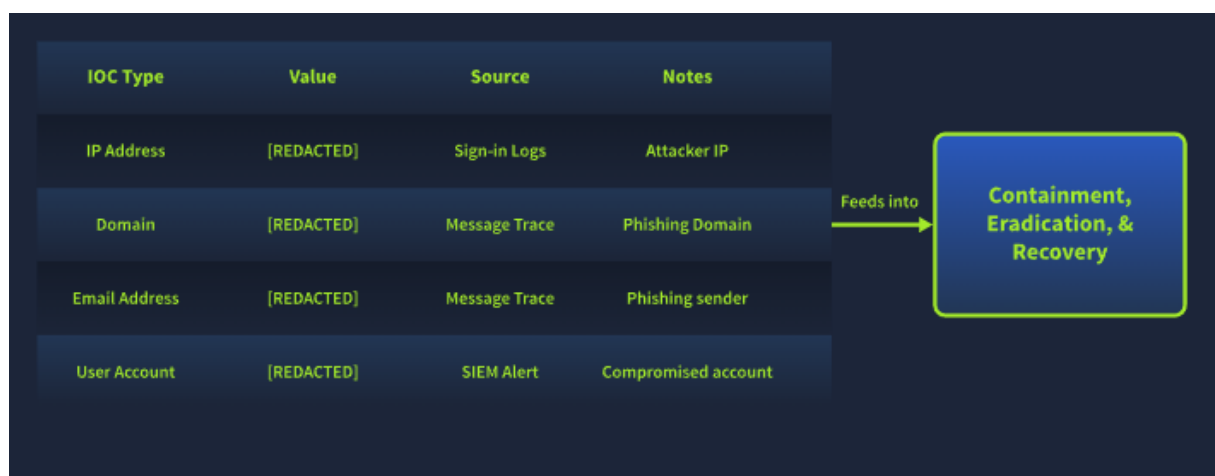
Asset inventory and the IOC tracker provide a structured way to map what exists in the environment and track every malicious indicator found during the investigation.

Asset inventory – reference document that lists all systems, devices and platforms within the organization. During analysis, the IR team uses it to answer questions like: which systems did this account have access to? Who owns this IP address (internally)? What other accounts are associated with this workstation?

IOC tracker – it is a running record of every indicator of compromise discovered during the investigation. It starts with whatever triggered the incident and grows with every new finding. Each entry records the IOC type, its value, where it was found.

Common IOC types:

IP address	Attacker's sign-in IP flagged as malicious
Domain	Phishing domain used to harvest credentials
Email address	Sender address used to deliver the phishing mail
User account	Compromised account used by the attacker
File name	Malicious file downloaded or accessed during the attack



PRACTICAL

In the **Preparation** room, you reviewed Nexus Financial's preparation state and found an organization with critical gaps left unaddressed. No **MFA** on standard user accounts, missing email authentication controls, a previous **phishing** incident closed without fixing the root cause, and detection rules that did not cover key threat scenarios. It looks like those gaps have now been exploited.

An anomalous sign-in alert was raised by the **SIEM** platform and triaged by Marcus Webb, Nexus Financial's L1 Security Analyst. Marcus confirmed the alert as a true positive and escalated it. You have been assigned to the investigation as the L2 analyst responsible for validating Marcus's findings and leading the full **IR** investigation.

Below is the **SIEM** alert that Marcus Webb received and triaged.

Alert Details:

- **Alert Name:** Anomalous Sign-in Detected
- **Time:** 2026-03-30 16:41:30
- **Affected Account:** l.chen@nexusfinancial.thm
- **Corporate IP:** 197.32.45.112

After triaging the alert, Marcus marked the alert as a true positive and raised the following escalation ticket.

A **SIEM** alert triggered on a successful sign-in to a Nexus Financial user account from an IP address that was never observed in the environment before. All Nexus Financial employees work from the London office (IP: 197.32.45.112) and are expected to sign in from the corporate network. This sign-in came from outside the United Kingdom. Laura Chen (Finance Manager) has confirmed she did not initiate this sign-in. Initial triage indicates this is a true positive requiring full **IR** investigation.

Escalation Details:

- **Ticket ID:** NXF-SOC-2026-0312
- **Raised by:** Marcus Webb, Security Analyst (L1)
- **Assigned to:** **IR** Analyst (L2)
- **Severity:** High
- **Affected Account:** l.chen@nexusfinancial.thm

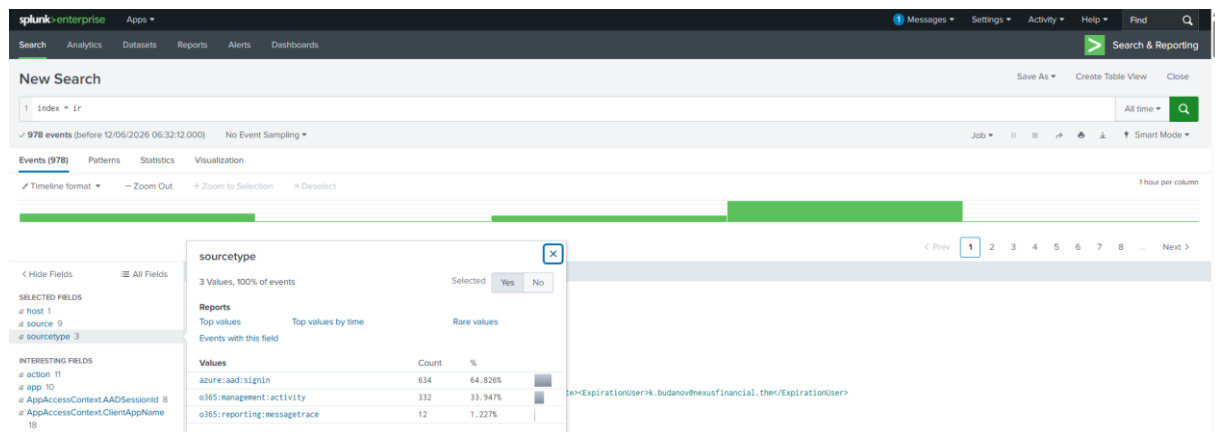


Available Log Sources

Nexus Financial's Microsoft 365 logs have been ingested into **Splunk** under the index **ir**. The following log sources are available across all practical tasks in this module:

Log Source	Sourcetype	Key Fields
Entra ID Sign-in Logs	azure:aad:signin	userPrincipalName, ipAddress, location.city, location.countryOrRegion, appDisplayName, status.errorCode
Message Trace	o365:reporting:messagetrace	Received, SenderAddress, RecipientAddress, Subject, Status, FromIP
Unified Audit Logs	o365:management:activity	Operation, UserId, Workload, ClientIP, ObjectID, SourceFileName, Name, SubjectContainsWords, DeleteMessage

So this is what our starting point looks like in Splunk:



The compromised account: l.chen@nexusfinancial.thm
Owner: Laura Chen, Finance manager

We begin with **detection phase** (we must confirm the suspicious activity in the logs and validate's Marucs's finding, and trace the attack back to its origin):

- 1) What was the IP address from which these suspicious sign-in events originated?

We know that the corporate IP is: 197.32.45.112, so we will filter everything that is not that + we will work with Entra ID sign-in logs which is basically access manager.

Command: **index = ir sourcetype="azure:aad:signin" AND ipAddress != 197.32.45.112**

The malicious IP address is: 223.123.4.50 (I also added the failure action)

The screenshot shows the Splunk interface with a search for 'ipAddress'. A modal window for 'ipAddress' is open, displaying a table of values.

Values	Count	%
223.123.4.50	3	100%

- 2) What city did the suspicious sign-in originate from?

The screenshot shows the Splunk interface with a search for 'location.city'. A modal window for 'location.city' is open, displaying a table of values.

Values	Count	%
Amsterdam	3	100%

- 3) What was the exact timestamp of the first suspicious sign-in on Laura Chen's account? (Format: YYYY-MM-DD HH:MM:SS)

We want to see the chronological order from the oldest to the newest entries. so we added **| sort _time** at the end of the query. The answer is: **2026-03-30 16:41:30**

```
> 30/03/2026 16:41:30.000 { [-]
  appDisplayName: OfficeHome
  appId: 4765445b-32c6-49b0-83e6-1d93765276ca
  appliedConditionalAccessPolicies: [ [+]
  ]
  clientAppUsed: Browser
  conditionalAccessStatus: success
  correlationId: f986f0f0-0792-47eb-aa14-d7587ad09376
  createdDateTime: 2026-03-30T16:41:30Z
  deviceDetail: { [+]
  }
  id: 4d3dcff9-6faa-45cd-934e-f4645caf0d00
  ipAddress: 223.123.4.50
  isInteractive: true
  location: { [+]
  }
  resourceDisplayName: OfficeHome
  resourceId: 4765445b-32c6-49b0-83e6-1d93765276ca
  riskDetail: none
  riskEventTypes: [ [+]
  ]
  riskEventTypes_v2: [ [+]
  ]
  riskLevelAggregated: none
  riskLevelDuringSignIn: none
  riskState: none
  status: { [+]
  }
  userDisplayName: Emma Clarke
  userId: 363b8dd0-1f29-483b-90c4-00b1ea5ebfbf
  userPrincipalName: l.chen@nexusfinancial.thm
```

- 4) What was the subject line of the email delivered to Laura Chen before the suspicious sign-in?

For this we have to use different log source which is Microsoft 365.

index = ir sourcetype="o365:reporting:messagetrace" | sort _time

```

> 30/03/2026 16:20:01.693 { [-]
    FromIP: 2a00:1450:4864:20::234
    MessageId:
    <CAA0ajKsy_vZw4BDjaiqNlt7HCpY1Kjxii+LK9rb1BW65PSvNxx@mail.gmail.com>
    MessageTraceId: be10618b-d445-472f-66b0-08de8e7831dc
    Received: 2026-03-30T16:20:01.693Z
    RecipientAddress: l.chen@nexusfinancial.thm
    SenderAddress: hr-support@nexus-verify.thm
    Size: 53776
    Status: Delivered
    Subject: HR Policy Update – Immediate Action Required
    ToIP:
  }
  Show as raw text
  host = ce-splunk
  source =
  /opt/splunk/var/spool/splunk/7dca1f226beb7acc_b7ddeef7bf6b4b1e_events.sta...
  sourcetype = o365:reporting:messagetrace

```

There were multiple cases of this malicious phishing email bombardment on other victim as well (k.patel@nexusfinancial.thm) and after initial access to Laura Chen, the attacker used her email address to look more trustworthy (example of Email Account Compromise (EAC)).

5) What was the sender domain of the phishing email?

nexus-verify.thm

Now we continue to **analysis**.

We have confirmed the initial compromise of Laura Chen's account and identified the phishing email that delivered it.

1) How many Nexus Financial accounts show sign-in activity from the attacker's IP?

We used the same command as at the beginning and opened the field user.

user

2 Values, 100% of events

Selected

Yes

No

Reports

Top values

Top values by time

Rare values

Events with this field

Values	Count	%	
k.patel@nexusfinancial.thm	39	68.421%	
l.chen@nexusfinancial.thm	18	31.579%	

Which shows us that two users were somehow connected to the suspicious activity.

2) What is the email address of the second compromised account?

k.patel@nexusfinancial.thm

3) What is the name of the inbox rule created on Laura Chen's account?

For this question we will go into Microsoft 365 management activity log source. At first I looked into Operation: Create, which didn't get me anywhere so the second option was the New-InboxRule which I have found out later.

New Search

Save As

Create Table View

Close

1 index = |r sourcetype="o365:management:activity" user="l.chen@nexusfinancial.thm"

2 | stats count by Operation

3 | sort _time

All time

✓ 126 events (before 12/06/2026 07:20:11.000) No Event Sampling

Job

Smart Mode

Events

Patterns

Statistics (23)

Visualization

Show: 20 Per Page

Format

Preview: On

< Prev

1

2

Next >

Operation	count
ClientViewSigned	2
Create	4
FileAccessed	26
FileDownloaded	3
FileModified	5
FileModifiedExtended	4
FilePreviewed	6
FolderCreated	2
FolderModified	2
ListViewed	3
MailItemsAccessed	21
MessageSent	1
New-InboxRule	1
PagePrefetched	1
PageViewed	14
PermissionLevelAdded	3
PlanListRead	18
SearchQueryPerformed	7
Send	3
SharingInheritanceBroken	2

And the name is: Junk Filter Update

```
30/03/2026 16:58:48.000 {"AppAccessContext": {"AADSessionId": "0032628a-fdd6-22ba-c173-01bacbe39fd9", "IssuedAtTime": "2026-03-30T16:37:04", "UniqueTokenId": "8HYxc9F30yVpP83s0ePAA"}, "CreationTime": "2026-03-30T16:58:48", "Id": "348388ce-8917-4cf6-27a8-08de8e7d9ce0", "Operation": "New-InboxRule", "OrganizationId": "d3711f14-7b27-49f8-9256-37bad364169d", "RecordType": 1, "ResultStatus": "True", "UserKey": "l.chen@nexusfinancial.thm", "UserType": 2, "Version": 1, "Workload": "Exchange", "ClientIP": "223.123.4.50:13651", "ObjectId": "EURPR10A007.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/nexusfinancial.thm/363b8dd8-1f29-483b-90c4-00b1ea5ebfbf/Junk Filter Update", "UserId": "l.chen@nexusfinancial.thm", "AppId": "", "AppPoolName": "MSEExchangeOWAAppPool", "ClientAppId": "", "CorrelationId": "", "ExternalAccess": false, "OrganizationName": "nexusfinancial.thm", "OriginatingServer": "PAXPR10M4688 (15.20.9745.823)", "Parameters": [{"Name": "AlwaysDeleteOutlookRulesBlob", "Value": "False"}, {"Name": "Force", "Value": "False"}, {"Name": "OrganizationName", "Value": "Junk Filter Update"}, {"Name": "SubjectContainsWords", "Value": "security;alert;suspicious;password;verify"}, {"Name": "DeleteMessage", "Value": "True"}, {"Name": "StopProcessingRules", "Value": "True"}], "RequestId": "61d34db-0bfc-e0fd-02b0-eee73585f5df", "SessionId": "0032628a-fdd6-22ba-c173-01bacbe39fd9", "TokenObjectId": "363b8dd8-1f29-483b-90c4-00b1ea5ebfbf", "TokenTenantId": "d3711f14-7b27-49f8-9256-37bad364169d"}
Show syntax highlighted
```

4) How many Nexus Financial employee accounts received the initial phishing email?

This question we have already found out at the beginning. The answer is 2.

Response and Recovery

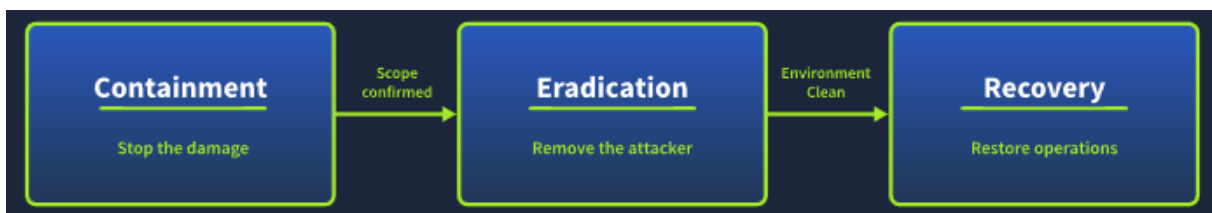
The attacker got himself into the company's environment. The Detection and Analysis phase confirmed the compromise, identified the affected accounts, and mapped the initial attack chain. This part focuses on resolving and responding to the incident.

When a security incident is confirmed, the investigation phase is over, and the response phase begins. This is the time for action. We divide the response into three actions:

Activity	Goal	Key question
Containment	Stop the damage from spreading any further	What do we need to cut off right now?
Eradication	Remove all attackers' presence from the environment	Is the attacker completely gone?
Recovery	Restore normal operations safely	Can we bring things back online without risk?

A common mistake IR teams make is moving to eradication before containment is complete, or recovering systems before the attacker has been fully removed. > This leads to the attacker regaining access and the team is back to square one.

The environment matters as well. An endpoint compromise requires different responses than a cloud identity compromise. This is where playbooks become valuable. A playbook is a pre-defined, step-by-step response guide tailored to a specific incident type and environment. Rather than figuring out the right containment and eradication actions from scratch during a live incident, the IR team follows a playbook built for exactly this scenario. A well-maintained playbook library means responses are faster, more consistent, and less dependent on any single analyst's knowledge.



When the attacker is active inside an environment, every minute they remain uncontained is a minute they can use to access more data, compromise more accounts, or establish further persistence. Containment doesn't mean the attacker is gone. It means their ability to cause further harm has been limited while the IR team works on removing them completely. Think of it as closing the doors before the fire spreads to other rooms. The fire is still there, but it is no longer growing.

There are two types of containment = isolation:

- 1) Full isolation – most aggressive approach. Affected accounts are disabled, active sessions are terminated, and the attacker’s access is completely cut off. Attackers will have to therefore use persistence if it was established.
- 2) Controlled isolation – less aggressive approach. Rather than cutting off the attacker immediately, the IR team monitors their activity closely while limiting what they can access. This allows the team to gather more intelligence before acting. The risk is that the attacker continues operating, even in a limited capacity, during this period.

Stopping the damage in a Microsoft 365 environment

Because this incident occurred entirely within Microsoft 365, stopping the damage does not involve unplugging network cables or isolating physical machines. There are no on-premises systems to segment. Instead, containment is performed through identity and access controls within the Microsoft 365 and Entra ID platforms.

MITRE ATT&CK and containment decisions

MITRE ATT&CK is a framework that documents the tactics, techniques and procedures used by real threat actors. Mapping an attacker’s action to MITRE ATT&CK techniques helps the IR team understand what the attacker is trying to achieve and anticipate what they might do next. This directly informs which containment actions to prioritize.

These are the techniques that were identified during the Detection and Analysis phase:

Technique ID	Technique Name	What the attacker did	Containment response
T1566	Phishing	Sent phishing emails to steal credentials	Block phishing domain at the email gateway
T1078	Valid Accounts	Used stolen credentials to sign in as legitimate users	Disable accounts, revoke sessions, reset passwords
T1564.008	Email Hiding Rules	Created inbox rules to suppress security alert emails	Remove the malicious inbox rules immediately
T1213	Data from Information repositories	Accessed SharePoint to download sensitive files	Review and restrict SharePoint permissions

Eradication

Eradication is the process of removing every trace of the attacker from the environment. Containment stopped them from causing more damage, but the attacker may still have a foothold. Malicious inbox rules, OAuth app permissions, persistence mechanisms, or additional accounts they access all need to be found and removed before the environment can be considered clean.

The most important principle here is: do not start eradication until the full scope is confirmed. Cleaning up a known compromise while missing a secondary one gives the attacker a path back in.

This incident is Microsoft 365 identity compromise, the clean-up forces on the identity layer rather than endpoints or network infrastructure. We can identify which of these eradication steps applies to what you find in the logs:

- Enforcing MFA on all compromised accounts before re-enabling them
- Removing all malicious inbox rules from affected mailboxes
- Reviewing and revoking any OAuth application permissions granted during the compromise
- Confirming that no additional accounts were accessed from the attacker's IP
- Revoking all external sharing links created by the attacker from SharePoint
- Confirming that no forwarding rules or delegates were added to affected mailboxes

Recovery

Recovery is the process of safely returning to normal operations. It is not simply a matter of re-enabling accounts and moving on. Before any affected account is brought back online, the IR team must confirm that eradication is complete and that the controls that failed during the incident have been addressed.

Recovery also means fixing the root causes that allowed the incident to happen in the first place. In a Microsoft 365 identity incident, root causes typically fall into two categories: identity controls that were missing or misconfigured, and email security controls that allowed the initial phishing to succeed. Both must be addressed before recovery can be considered complete.

Recovery actions are planned across three timeframes. In the practical task, you will be tasked to place specific recovery actions into the correct timeframe based on what you find in the logs:

Timeframe	Focus	Example Actions
Near term	Immediate actions before accounts can be re-enabled	Enforce MFA, reset passwords, remove malicious rules, and revoke external shares
Mid term	Controls that address the root causes of the incident	Configure SPF, DKIM and DMARC, implement conditional access policies and review SharePoint permissions Sender Policy Framework (SPF) is an email authentication method designed to detect forging sender addresses during the delivery of the email. DKIM (DomainKeys Identified Mail) is an email security standard designed to make sure messages aren't altered in transit between the sending and recipient servers. Domain-based Message Authentication, Reporting, and Conformance, or DMARC, is a technical standard that helps protect email senders and recipients from spam, spoofing, and phishing.
Long term	Improvements to the overall security posture	Expand SIEM detection rule coverage, run phishing simulations, and update IR policy with escalation timelines

PRACTICAL

The **Detection and Analysis** room confirmed that a targeted **phishing** attack was carried out against Nexus Financial. Two employee accounts were compromised through credential theft. The attacker signed in from an overseas IP address, created malicious inbox rules on the compromised accounts to suppress security alerts, and used the first compromised account to send internal **phishing** emails to other employees.

The **IR** team has been notified. Initial containment steps are being prepared but have not yet been executed. Before any containment action is taken, the team needs a complete picture of what the attacker did inside the environment after gaining access. That is your job in this room.

Below is the initial **SIEM** alert that Marcus Webb (**SOC L1**) received and triaged. This initiated the **IR** investigation.

- Alert Details:**
- **Alert Name:** Anomalous Sign-in Detected
 - **Time:** 2026-03-30 16:41:30
 - **Affected Account:** l.chen@nexusfinancial.thm
 - **Corporate IP:** 197.32.45.112

IOC Type	Value	Hint (if starting from this room)
Attacker IP Address	223.123.4.50	Search Entra ID sign-in logs for l.chen@nexusfinancial.thm and look for sign-ins from outside the corporate IP 197.32.45.112
Phishing Sender Address	hr-support@nexus-verify.thm	Search Message Trace for emails delivered to l.chen@nexusfinancial.thm from external senders before the suspicious sign-in
Compromised Account 1	l.chen@nexusfinancial.thm	Confirmed in the SIEM alert above
Compromised Account 2	k.patel@nexusfinancial.thm	Search Entra ID sign-in logs for any other Nexus Financial accounts that show sign-in activity from the attacker's IP
Malicious Inbox Rule	Junk Filter Update	Search Unified Audit Logs for New-InboxRule operations on l.chen@nexusfinancial.thm from the attacker IP

CONTAINMENT PRACTICAL

The Detection and Analysis phase confirmed that two accounts are compromised and an attacker has been active inside the Nexus Financial Microsoft 365 environment. Before the IR team executes containment actions, they need to understand exactly what the attacker did after gaining access. Your job is to investigate that post-compromise activity. Focus on the Unified Audit logs, this is where post-compromise activity is recorded.

Examine the operations performed on both compromised accounts after the attacker signed in. Check for persistence mechanisms on both mailboxes, any emails sent from the compromised accounts that suggest lateral movement and any SharePoint activity that indicated data access.

- 1) What keywords does the malicious inbox rule on Laura Chen's account filter for?
(Answer in the same format as inside the log)

We used the same query as before:

```
index = ir sourcetype="o365:management:activity"  
user="l.chen@nexusfinancial.thm"
```

| stats count by Operation

| sort _time

- 2) What is the value of the DeleteMessage field in the malicious inbox rule on Laura Chen's account?

True

- 3) What is the name of the inbox rule created on the second compromised account?

For this task we have just exchanged the account name and gotten:

```
{ "AppAccessContext": { "AADSessionId": "0032628a-18de-c461-1ea4-2904a5de4b49", "IssuedAtTime": "2026-03-30T16:56:07", "UniqueTokenId": "2BwKfp7bb0CWXYdTL82AA"}, "CreationTime": "2026-03-30T17:02:40", "Id": "e4bee642-ffc4-443e-bb96-08de8e7e26fd", "Operation": "New-InboxRule", "OrganizationId": "d3711f14-7b27-49f8-9256-37bad364169d", "RecordType": 1, "ResultStatus": "True", "UserKey": "k.patel@nexusfinancial.thm", "UserType": 2, "Version": 1, "Workload": "Exchange", "ClientIP": "223.123.4.50:25487", "ObjectId": "EURPR10A007.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/nexusfinancial.thm/eb11d9b1-3e98-49bf-b2c2-19a497641751\\Security Updates", "UserId": "k.patel@nexusfinancial.thm", "AppId": "", "AppPoolName": "MSExchangeOWAAppPool", "ClientAppId": "", "CorrelationId": "", "ExternalAccess": false, "OrganizationName": "nexusfinancial.thm", "OriginatingServer": "AM6PR10MB2280 (15.20.9654.014)", "Parameters": [ { "Name": "AlwaysDeleteOutlookRulesBlob", "Value": "False" }, { "Name": "Force", "Value": "False" }, { "Name": "Name", "Value": "Security Updates" }, { "Name": "SubjectContainsWords", "Value": "security;alert;password" }, { "Name": "DeleteMessage", "Value": "True" }, { "Name": "StopProcessingRules", "Value": "True" } ], "RequestId": "9b6cfecd-5528-295f-8031-b5fa7b52ada5", "SessionId": "0032628a-18de-c461-1ea4-2904a5de4b49", "TokenObjectId": "eb11d9b1-3e98-49bf-b2c2-19a497641751", "TokenTenantId": "d3711f14-7b27-49f8-9256-37bad364169d" }
```

- 4) Based on Task 3, what containment action should be taken against these inbox rules?

Remove the malicious inbox rules immediately

- 5) How many internal Nexus Financial employees received the internal phishing email?

We know that the initial phishing email received two people (l.chen and k.patel), in our Splunk query we added them to SenderAddress field and we must start looking at logs after 16:20:01, which is the time of the first phishing email attack on l.chen.

index = ir sourcetype="o365:reporting:message" SenderAddress=l.chen@nexusfinancial.thm OR k.patel@nexusfinancial.thm | sort _time

```
30/03/2026 16:57:09.000 { [-]
  FromIP: 223.123.4.50
  MessageId:
  <PAXPR10MB46883CA6D95CD59B619EE741B352A@PAXPR10MB4688.EURPRD10.PROD.OUTLOOK
  MessageTraceId: e7e84cc7-3833-4b13-d24c-08de8e7d61b6
  Received: 2026-03-30T16:57:09.461Z
  RecipientAddress: allan.senna@nexusfinancial.thm
  SenderAddress: l.chen@nexusfinancial.thm
  Size: 39179
  Status: Delivered
  Subject: HR Policy Update - Immediate Action Required
  ToIP:
}
Show as raw text
host = ce-splunk
source =
/opt/splunk/var/spool/splunk/7dcaf226beb7acc_b7ddeef7bf6b4b1e_events.sta...
sourcetype = o365:reporting:message
```

```
30/03/2026 16:57:09.000 { [-]
  FromIP: 223.123.4.50
  MessageId:
  <PAXPR10MB46883CA6D95CD59B619EE741B352A@PAXPR10MB4688.EURPRD10.PROD.OUTLOOK
  MessageTraceId: e7e84cc7-3833-4b13-d24c-08de8e7d61b6
  Received: 2026-03-30T16:57:09.461Z
  RecipientAddress: m.harris@nexusfinancial.thm
  SenderAddress: l.chen@nexusfinancial.thm
  Size: 39179
  Status: Delivered
  Subject: HR Policy Update - Immediate Action Required
  ToIP:
}
Show as raw text
host = ce-splunk
source =
/opt/splunk/var/spool/splunk/7dcaf226beb7acc_b7ddeef7bf6b4b1e_events.sta...
sourcetype = o365:reporting:message
```

```
30/03/2026 16:57:09.000 { [-]
  FromIP: 223.123.4.50
  MessageId:
  <PAXPR10MB46883CA6D95CD59B619EE741B352A@PAXPR10MB4688.EURPRD10.PROD.OUTLOOK
  MessageTraceId: e7e84cc7-3833-4b13-d24c-08de8e7d61b6
  Received: 2026-03-30T16:57:09.461Z
  RecipientAddress: k.patel@nexusfinancial.thm
  SenderAddress: l.chen@nexusfinancial.thm
  Size: 39179
  Status: Delivered
  Subject: HR Policy Update - Immediate Action Required
  ToIP:
}
Show as raw text
host = ce-splunk
source =
/opt/splunk/var/spool/splunk/7dcaf226beb7acc_b7ddeef7bf6b4b1e_events.sta...
sourcetype = o365:reporting:message
```

k.patel received it again from the l.chen

- 6) Based on Task 3, what containment action should be taken against the phishing domain?

Block phishing domain at the email gateway

ERADICATION AND RECOVERY PRACTICAL

Containment has stopped the attacker from causing further damage. Now the focus shifts to two things: confirming the full extent of what the attacker accessed and exfiltrated and identifying the root causes that allowed this incident to happen. Both must be fully understood before the environment can be considered clean and safe to recover.

- 7) How many files were downloaded from SharePoint across both compromised accounts?

```
index = ir sourcetype="o365:management:activity" l.chen@nexusfinancial.thm OR k.patel@nexusfinancial.thm Workload=SharePoint signature=FileDownloaded | sort _time
```

We need to check the time from 16:20:00. There are five in total.

The screenshot shows the Splunk Search interface. The search bar contains the query: `index = ir sourcetype="o365:management:activity" l.chen@nexusfinancial.thm OR k.patel@nexusfinancial.thm Workload=SharePoint signature=FileDownloaded | sort _time`. The search results show 5 events. The table below displays the first five events.

	_time	host	source
>	30/03/2026 16:55:24.000	ce-splunk	/opt/splunk/var/spool/splunk/7858c6296bebdb8e_f29e68cca50667f7_ev
>	30/03/2026 16:55:33.000	ce-splunk	/opt/splunk/var/spool/splunk/7858c6296bebdb8e_f29e68cca50667f7_ev
>	30/03/2026 16:55:37.000	ce-splunk	/opt/splunk/var/spool/splunk/7858c6296bebdb8e_f29e68cca50667f7_ev
>	30/03/2026 17:03:38.000	ce-splunk	/opt/splunk/var/spool/splunk/58db644ebc3e6e46_ea2e5f8857beef44_ev
>	30/03/2026 17:03:45.000	ce-splunk	/opt/splunk/var/spool/splunk/58db644ebc3e6e46_ea2e5f8857beef44_ev

- 8) What is the name of the first file downloaded by the attacker from Laura Chen's account?

	i	Time	Event
30/03/2026 16:55:24.000	{ [-]		
			<pre> AppAccessContext: { [+] } ApplicationDisplayName: Browser AuthenticationType: FormsCookieAuth BrowserName: Chrome BrowserVersion: 146.0.0.0 ClientIP: 223.123.4.50 CorrelationId: 8c1d05a2-d02e-0000-d69c-35001411ec4e CreationTime: 2026-03-30T16:55:24 DeviceDisplayName: 2a01:111:2053:2a00::ad4:481c EventSignature: 1.CAESDkZpbGVEb3dubG9hZGVkGPzVqs4GIhAxMDAzMjAwNWE3OTM5ZGJlMhIJMoxTjW4FbkMRoeZHsgCHxjc6Egn wbkjbPShGFHMicdWIDRUISCZ8pdEHyiehJEYhGoWzKwM12ShIJT1l6h6L0sRq2Ah1176fyI.7IcRnD0-jzFrI3ubNKcXub_EHncA74Cky3 EventSource: SharePoint FileSizeBytes: 48775 GeoLocation: EUR HighPriorityMediaProcessing: false Id: 74c37ce8-88ad-4dfd-7497-08de8e7d2345 IsManagedDevice: false ItemType: File ListBaseType: 1 ListId: 4174299f-89f2-49e8-8846-a16ccac0cd76 ListItemUniqueId: b76e594f-7aa8-4b2f-ab60-21d65efa7f22 ListServerTemplate: 101 ObjectId: https://nexusfinancial.sharepoint.com/sites/Finance-department/Shared Documents/Board_Meeting_Notes_July.docx Operation: FileDownloaded OrganizationId: d3711f14-7b27-49f8-9256-37bad364169d Platform: MacOSX RecordType: 6 Site: 8d6d8c32-056e-436e-a1e6-47b20087c637 SiteUrl: https://nexusfinancial.sharepoint.com/sites/Finance-department/ SourceFileExtension: docx SourceFileName: Board_Meeting_Notes_July.docx SourceRelativeUrl: Shared Documents UserAgent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/ Safari/537.36 UserId: l.chen@nexusfinancial.thm UserKey: i:0h.f membership 10032005a7939dbe@live.com UserType: 0 Version: 1 WebId: 1bec83db-9690-4acf-851c-c89c75688345 Workload: SharePoint </pre>

The filename is: **Board_Meeting_Notes_July.docx**

- 9) Based on Task 4, what eradication action should be taken against the external sharing links created by the attacker?

Revoking all external sharing links created by the attacker from SharePoint

- 10) What risk level was assigned to the attacker's sign-ins by Microsoft's risk engine?

index = ir sourcetype="azure:aad:signin" user_id=k.patel@nexusfinancial.thm OR l.chen@nexusfinancial.thm

| sort _time

The risk is unfortunately none, because the system didn't notice the sign-in IP address was totally different from the corporal one.

riskState

X

1 Value, 100% of events

Selected

Yes

No

Reports

Top values

Top values by time

Rare values

Events with this field

Values	Count	%
none	634	100%

```
30/03/2026 { [-]
16:47:17.000  appDisplayName: SharePoint Online Web Client Extensibility
               appId: 08e18876-6177-487e-b8b5-cf950c1e598c
               appliedConditionalAccessPolicies: [ [+]
               ]
               clientAppUsed: Browser
               conditionalAccessStatus: success
               correlationId: 4e42d5ce-0b7f-430a-8c17-a41cadd2b32b
               createdDateTime: 2026-03-30T16:47:17Z
               deviceDetail: { [+]
               }
               id: 8dfcfcfb-7d06-41b6-8bc0-babf95f14d00
               ipAddress: 223.123.4.50
               isInteractive: true
               location: { [+]
               }
               resourceDisplayName: Microsoft Graph
               resourceId: 00000003-0000-0000-c000-000000000000
               riskDetail: none
               riskEventTypes: [ [+]
               ]
               riskEventTypes_v2: [ [+]
               ]
               riskLevelAggregated: none
               riskLevelDuringSignIn: none
               riskState: none
               status: { [+]
               }
               userDisplayName: Emma Clarke
               userId: 363b8dd0-1f29-483b-90c4-00b1ea5ebfbf
               userPrincipalName: l.chen@nexusfinancial.thm
           }
Show as raw text
host = ce-splunk
source =
/opt/splunk/var/spool/splunk/843608e05279f0a3_c406bbb07124ac02_events...
sourcetype = azure:aad:signin
```

11) What authentication control was absent that allowed the attacker to sign in without additional verification? (Please input the abbreviation of the term)

MFA was not present at all, more precisely not enabled.

```
ame": "Require MFA", "enforcedGrantControls": [], "enforcedSessionControl
s": [], "result": "notEnabled"}, {"id": "55f8f245-7489-429c-a3d2-fca8ba0618
b1", "displayName": "Allow Risky Users", "enforcedGrantControls": ["Mfa"],
"enforcedSessionControls": [], "result": "notApplied"}, {"id": "8c000165-bc
e5-447c-93ce-eddc23ca8c42", "displayName": "Require-MFA-Risky-Users-Sign-I
n", "enforcedGrantControls": [], "enforcedSessionControls": [], "result":
"notEnabled"}, {"id": "8b3aa6a4-e7ac-4350-9336-6457b7f1d070", "displayNam
e": "Block Suspicious Countries", "enforcedGrantControls": ["Block"], "enfo
rcedSessionControls": [], "result": "notApplied"}]]
Show syntax highlighted
```

12) According to the recovery timeframes in Task 4, what timeframe should MFA enforcement fall under?

Timeframe	Focus	Example Actions
Near term	Immediate actions before accounts can be re-enabled	Enforce MFA, reset passwords, remove malicious rules, and revoke external shares

POST-INCIDENT ACTIVITY (phase where the intelligence is gathered)

The attacker has been contained, eradicated, and the environment is clean. But the work is not finished. The final phase of the NIST incident response framework is post-incident activity, the phase where the organization steps back, reflects on what happened, documents the findings, and uses everything learned to become harder to attack next time.

Every security incident contains valuable information that can help the SOC to mature its defense capabilities. The attacker's methods, the gaps they exploited, the controls that failed, and the controls that worked, all of it is intelligence that can be used to strengthen the organization's defenses.

Lessons learned meeting

It is a structured discussion held after the incident is resolved. It brings together everyone involved in the response, the IR team, relevant stakeholders, and, in some cases, IT and management, to review what happened and what can be improved.

The meeting addresses these questions:

- What exactly happened, and what was the root cause?
- How did the attacker gain initial access, and what vulnerability was exploited?
- When was the incident detected, and what triggered the detection?
- Could it have been detected earlier, and if so, how?
- What went well during the response, and what did not?
- What changes to people, processes or technology, would prevent this from happening again?

This eventually becomes part of new detection rules, updated policies, additional training, and changes to the technology stack all result from this process.

The NIST SP 800-61r2 connects Post-Incident activity back to Preparation phase. Everything learned in this phase improves the organization's readiness for the next incident.

Reporting the incident

After the incident, the IR team is responsible for producing documentation for two very different audiences. First, the technical staff needs a detailed record of what happened, what was found, and what was done. Second, the leadership and stakeholders need a clear, concise account of the business impact and the actions taken to resolve it. These

two are covered by two different documents: the technical summary and the executive summary.

The Executive Summary

Written for non-technical audience (business impact of the incident). The CIO, CEO, legal counsel and board members are typical readers of an executive summary.

What happened	Describe in simple language what type of attack occurred and what systems or data were affected
Business impact	Summaries whether data was lost, operations were disrupted, and whether there is any regulatory exposure
How it was discovered and resolved	Provide a high-level timeline of how the incident was detected and what steps were taken to resolve it.
Prevention and Remediation	Outline the actions being taken to prevent reoccurrence, described in plain language

DOESN'T INCLUDE: IP addresses, domain names, MITRE technique IDS, SPL queries etc..

The Technical Summary

Written for all technical teams, including the IR team, security engineers and IT staff. Its purpose is to provide a complete and precise record of the incident that can be used for evidence, future reference and as a basis for improving defenses.

Full attack timeline	Every event in sequence with exact timestamps from the logs, from the first malicious action to containment.
IOCs	All indicators of compromise discovered during the investigation, including IP addresses, domains, email addresses, file names, accounts names etc...
MITRE ATT&CK techniques	Every technique that was identified during the incident.
Log evidence	The specific log sources, queries and raw log entries used to confirm each finding
Root causes	The security control gaps that allowed the incident to occur and the remediation steps taken to address them
Detection gaps	The attacker behaviors that were not caught by existing alerts, and the detection rules added as a result.

Strengthening the Defenses

From TTPs to Detection rules

Every TTP (Tactic, technique and procedure) identified during the investigation corresponds to a specific attacker behavior recorded in the logs. The next time an attacker uses the same approach, the SOC will know within minutes rather than hours or days.

The False positive problem

Writing a good detection rule is difficult. The challenge is that many attackers' behaviors are similar to those of normal users. Creating an inbox rule if employees do something regularly for legitimate reasons. Downloading files from SharePoint is normal. Signing in from a new location can also mean someone is traveling. So if such rule is created, it also creates many false positive aka benign alerts which pose zero risk and are just alert of normal usage > alert fatigue (and thus missing the real threat).

Good detection rules catch attacker behavior by looking for anomalies, combinations of events (correlation) or conditions that are unusual. For example:

- An inbox rules created by an account that signed in from a new country in the last hour
- Many files downloaded from SharePoint within a short timeframe from a single account
- A successful sign-in from an IP address that has never been seen in the environment with no MFA

This module focuses on incident response for Microsoft 365 activity, so it is important to know several tools are designed specifically for post-incident investigation of Microsoft 365 environments,

Hawk	It is an open-source PowerShell tool for gathering forensic data from Microsoft 365 environments, including mailbox activity, admin actions and sign-in logs
Sparrow	It was developed after high-profile cloud incidents. Checks for IOCs specific to Microsoft 365 and Azure environments
Microsoft Secure Score	It is a measurement of the organization's security posture across Microsoft 365 services, useful for identifying remaining gaps after an incident.

PRACTICAL

The attacker has now been contained, and the environment is clean. This task will bring together everything discovered across the investigation into a post-incident review. We will document the key findings for a technical summary, map the attacker's behavior to the MITRE ATT&CK framework, assess the incident's business impact, and build detection rules to ensure this attack is automatically detected in the future.

Some of these questions do not require Splunk. They test your understanding of what happened in the full investigation. The other ones will require you to go back to the logs to confirm specific values. Use the log sources, sourcetypes, and fields listed in Task 5 to build your queries where needed.

Documenting the Findings

The questions below represent the kind of findings that would appear in both the technical summary and the lessons learned report for the Nexus Financial incident. Work through them carefully. Together, they tell the complete story of the attack.

What Would Happen Next

The findings you document here would be used for two outputs. First is the technical summary, which would include the full IOC list, MITRE technique mappings, the timeline, and the root cause analysis. Second is the executive summary, which would highlight the business impact, regulatory considerations, and the controls being put in place to prevent recurrence. Both documents would be presented at the company's lessons learned meeting and used to drive improvements to its security posture.

- 1) What was the initial attack vector used to compromise Laura Chen's account?

Phishing e-mail. The sender was: hr-support@nexus-verify.thm

- 2) Even after the victim entered their credentials on the phishing page, what security control would have prevented the attacker from gaining access? (Please input the abbreviation of the term)

MFA – Multi-factor authentication, which unfortunately was disabled or not present at all.

- 3) How many employees were put at risk by the internal phishing email?

There were three people that received the internal phishing email. (k.patel received the email both externally – unsuccessfully and internally – successfully)

- 4) What was the first log source that identified the suspicious activity?

It was the sign-in log source. > Entra ID Sign-in Logs

- 5) Which file downloaded by the attacker contains personally identifiable information of Nexus Financial employees?

file_name ×

16 Values, 30.723% of events

Selected

Reports

[Top values](#) [Top values by time](#) [Rare values](#)

Events with this field

Top 10 Values	Count	%
Full_Employee_PII_Data.xlsx	17	16.667%
Q3_Financial_Report.xlsx	13	12.745%
__siteIcon__.png	12	11.765%
Employee_Salary_Data.xlsx	11	10.784%
Board_Meeting_Notes_July.docx	10	9.804%
Payroll_Q3_2024.xlsx	8	7.843%
Untitled_Section.one	6	5.882%
AllItems.aspx	5	4.902%
ByAuthor.aspx	4	3.922%
Documents	4	3.922%

I used this query : `index="ir" sourcetype="o365:management:activity | sort _time"` and checked the filenames and it was definitely the top 10 mentioned file. I could also go manually through the few logs from the time 16:20:01 and find out the file, there were also other files like : `Q3_Financial_Report.xlsx` or `Employee_Salary_Data.xlsx`, but they didn't contain PII which we were looking for.

- 6) For improving future detections, which Operation is relevant to highlight for detecting suspicious Inbox Rule Creations?

New-InboxRule, I just guessed it, because that was the name of the rule created by the attacker.

- 7) For improving the future detections, which field in Entra ID logs can be used to detect authentications coming from unusual countries?

```
a location.city 2
a location.countryOrRegion 2
a location.geoCoordinates.altitude 1
# location.geoCoordinates.latitude 2
# location.geoCoordinates.longitude 2
a location.state 2
```

I root for both of them, because they are almost the same thing.